



AIRSHIELD

PRIVATE AI CONTROL PLANE

EXECUTIVE • ARCHITECTURE • COMMERCIAL

Executive Architecture & Business Dossier

A privacy firewall for AI voice and text workflows

**Keep the intelligence.
Remove the identifiers.**

For executive, client, architecture, security, privacy, and product discussions
English-first • self-hosted • provider-neutral • Azure-private or portable Kubernetes

CAPTURE

PROTECT

AUTHORIZE

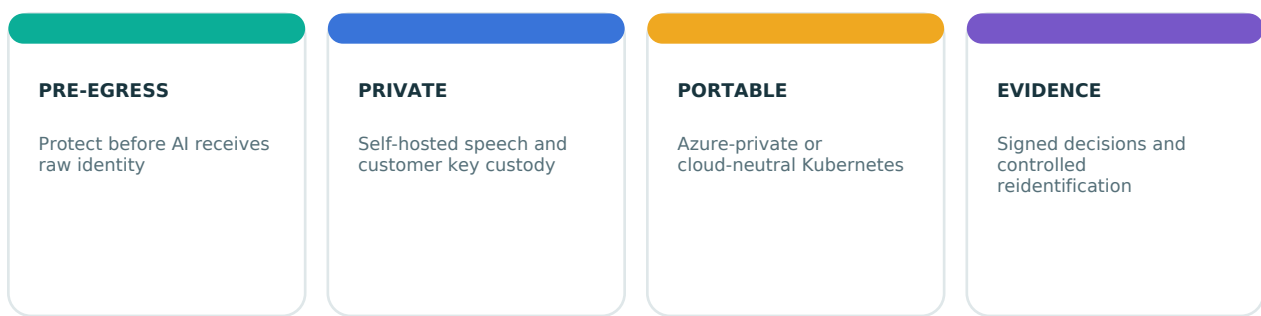
PROVE

Contents

Architecture, integration, commercial case, assurance, and executive decisions

1. Executive brief	3
2. Why clients need this now	4
3. Priority uses	5
4. End-to-end business and data flow	6
5. Reference architecture	8
6. Security, identity, and data lifecycle	9
7. Integration with new web and mobile applications	11
8. Integration with legacy applications	11
9. Technology stack	13
10. Why AirShield is differentiated	14
11. Business model and go-to-market	15
12. ROI and executive scorecard	16
13. Pilot and production roadmap	17
14. What is implemented and what remains	18
15. Risks, objections, and responses	18
16. Questions a CEO is likely to ask	20
17. Product roadmap opportunities	21
18. Recommended executive decisions	22
Appendix A. Integration decision guide	22
Appendix B. Responsibility summary	23
Appendix C. Important assurance statement	23

1. Executive brief



The business problem

Organizations want AI-assisted calls, summaries, copilots, quality monitoring, claims automation, and document processing. Those workflows routinely contain names, phone numbers, patient identifiers, account numbers, payment data, addresses, credentials, and client-specific confidential values. In many architectures, the raw content reaches a model provider, telemetry pipeline, log store, analytics product, or support platform before privacy controls are applied.

This creates four executive-level blockers:

- 1 **Risk:** unnecessary exposure expands the impact of a breach, configuration error, or supplier incident.
- 2 **Approval friction:** security, privacy, legal, risk, and works councils may delay AI projects that have no credible pre-egress control.
- 3 **Cost and lock-in:** managed speech and model APIs charge by usage and receive raw content before an application can mask it.
- 4 **Weak evidence:** teams struggle to prove what policy ran, what destination was approved, and whether an unsafe request was blocked.

The AirShield answer

AirShield places a customer-controlled privacy boundary before downstream AI. It combines self-hosted English speech-to-text, optional speaker diarization, policy-driven PII/PHI/PCI detection, reversible tokenization with strict controls, destination allowlisting, and signed evidence. The product shows the raw local transcript beside the protected outbound transcript so business users, engineers, and auditors can understand what changed.

The outcome clients buy

Clients do not primarily buy redaction software. They buy:

- faster approval of sensitive AI use cases;
- less raw personal data sent to processors and tools;
- a reusable privacy control across models and applications;
- reduced manual redaction and review effort;
- clearer evidence for security, privacy, and risk governance;
- freedom to change AI providers without rebuilding the privacy layer.

Recommended executive message

“AirShield helps enterprises use AI on sensitive conversations and application data without making raw identifiers the default input to external models.”

2. Why clients need this now

Demand drivers

- AI copilots and summarization are moving from experiments into customer and employee workflows.
- Voice channels contain dense, unpredictable identity data and cannot rely on form-field validation alone.
- Security leaders want data minimization before content leaves a controlled environment.
- Privacy teams need purpose, retention, deletion, and reidentification controls—not only a masking regex.
- Enterprises increasingly use several model vendors and need one consistent policy layer.
- Regulated buyers expect evidence, tenant separation, private networking, key custody, and fail-closed behavior.
- Usage-based speech services can make large contact-center deployments expensive and create supplier dependence.

Client pain translated into buying value

Client pain	Business consequence	AirShield value
Raw customer or patient data enters AI prompts	Larger privacy and breach exposure	Protected text is created before approved AI routing
Security review blocks a promising AI project	Delayed benefit and executive frustration	A visible, testable control helps move the project into a governed pilot
Every application builds its own masking logic	Inconsistent policy and repeated engineering cost	Central policy and common APIs create one reusable control plane
Managed speech cost grows with every audio minute	Unpredictable operating expense	Self-hosted speech supports capacity-based economics
Auditors cannot reconstruct privacy decisions	Weak assurance and slow investigations	Signed, hash-linked metadata receipts support evidence workflows
Teams need an identifier later for an approved task	Permanent redaction breaks operations	Controlled, time-limited, dual-approved reidentification preserves utility
Legacy platforms cannot be rewritten	Transformation stalls	Sidecar, gateway, proxy, and adapter patterns minimize core-system change

Strongest initial client profiles

- 1 Healthcare providers, health-tech and clinical contact centers** using transcription, note drafting, scheduling, or patient support.
- 2 Banks, fintechs and payment-adjacent support operations** using agent assist, fraud review, quality analysis, or automated case notes.
- 3 Insurers and claims administrators** processing calls and documents containing identity, policy, health, and financial data.
- 4 BPO/contact-center operators** serving several clients and needing per-tenant policies and evidence.
- 5 SaaS vendors and internal AI platform teams** that need a privacy gateway before prompts reach local or hosted models.

The most qualified opportunity has an active AI initiative, sensitive conversational or text data, a security/privacy approval blocker, and an executive sponsor who values private deployment.

3. Priority uses

Healthcare

- Live patient-call transcription with local raw view and protected AI notes.
- Clinical or administrative note drafting from protected transcripts.
- Appointment, referral, and patient-support automation.
- EHR integration where controlled re-association is required.
- Privacy-safe quality review using protected content.

Typical entities include person, MRN, phone, email, address, date of birth, and client-defined clinical identifiers. AirShield is not a medical device diagnosis engine and must not be marketed as automatically HIPAA- or EHDS-certified.

Finance and payments

- Contact-center agent assist without exposing account or payment data to the model.
- Fraud-case summarization with destination and access controls.
- Support-ticket, chat, and complaint protection.
- Pre-processing of documents and logs before AI analysis.

Typical entities include person, account number, PAN/card number, phone, email, IFSC/bank code, address, dates, credentials, and custom reference formats. PCI scope and validation remain customer/acquirer/assessor decisions.

Insurance

- Claims-call transcription and summary.
- First-notice-of-loss intake.
- Broker and policyholder correspondence.
- Protected document and evidence extraction.

Typical entities include claimant, policy ID, date of birth, address, health information, bank details, vehicle/property identifiers, and adjuster notes.

BPO and contact centers

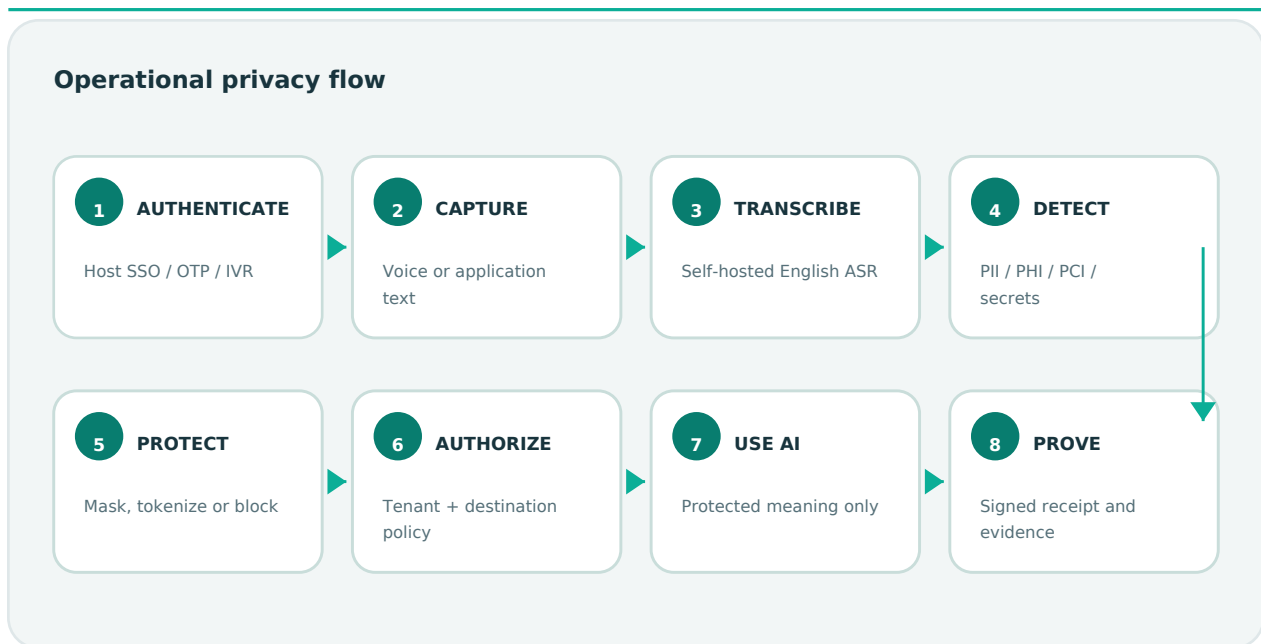
- Agent assist and post-call notes.
- Quality assurance and coaching datasets.
- Per-client policy templates within one operated platform.
- Safer transfer of protected data into ticketing, CRM, and analytics tools.

The commercial value is strongest when one platform can enforce different tenant policies without sharing token maps or evidence chains.

SaaS and internal copilots

- Protect prompts before they reach an enterprise model gateway.
- Remove secrets and personal data from support tickets, logs, and knowledge workflows.
- Apply consistent policy across browser, API, batch, and agentic workflows.
- Prevent downstream tools from receiving raw values unless explicitly authorized.

4. End-to-end business and data flow



Operational flow

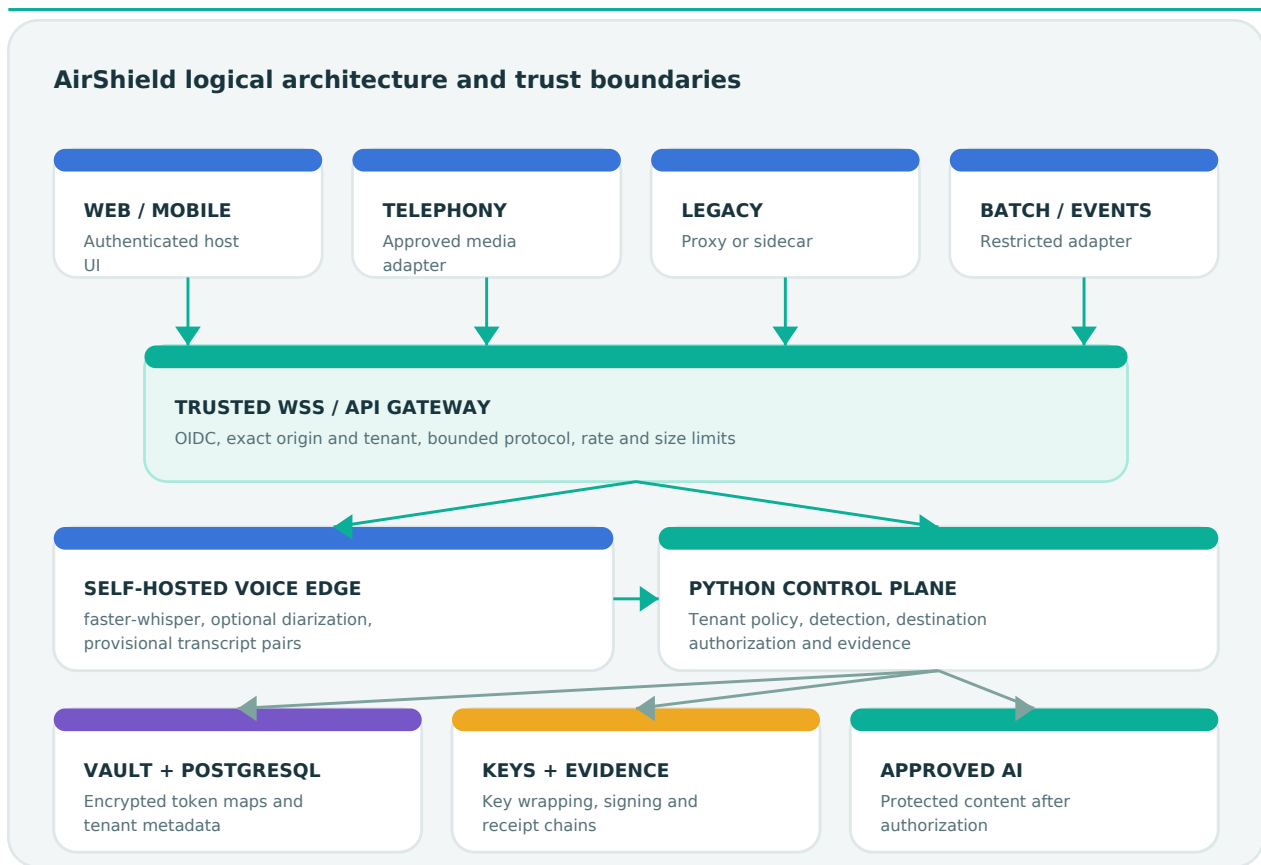
- 1 Start inside the trusted application.** The user authenticates through the client's SSO, OTP, IVR, CRM/EHR check-in, or another approved host process.
- 2 Capture voice or text.** Voice audio is streamed to the authenticated gateway; typed text enters a server-side protection API.
- 3 Transcribe privately.** The self-hosted edge runs English speech-to-text. Optional diarization maintains Speaker A/B/C continuity.
- 4 Bind identity only from trusted evidence.** The host may bind a verified subject to a speaker track. The LLM does not authenticate people, and voice similarity alone is not treated as proof.
- 5 Detect sensitive spans.** Deterministic recognizers, contextual analysis, and customer patterns identify relevant entities.
- 6 Apply policy.** The control plane chooses tokenize, mask, redact, generalize, review, or block according to tenant, industry policy, confidence, and destination.
- 7 Show the transformation.** Authorized users see raw content on the local side and the protected outbound representation on the other side.
- 8 Route only approved content.** Interim streaming text remains provisional. At session end, the complete transcript is rechecked. Only a signed final **allow** can be eligible for AI egress.
- 9 Use AI without raw identity by default.** The approved model receives protected meaning and returns a summary, recommendation, or structured result.
- 10 Re-associate only when justified.** If an approved workflow needs a real value, a purpose/ticket, separate approver, short expiry, and one-time requester retrieval are required.
- 11 Retain evidence, not raw content.** Metadata-only, signed, tenant-specific receipt chains record policy, destination, decision, entity counts, and content hashes.

Business adoption flow

- 1 Select one use case and one data owner.
- 2 Map data flows, roles, purposes, destinations, retention, and expected users.
- 3 Collect legally approved representative test data.
- 4 Configure entity and destination policy.

-
- 5 Integrate through the least invasive adapter pattern.
 - 6 Run accuracy, latency, security, privacy, and failure-mode gates.
 - 7 Pilot with human review and restricted destinations.
 - 8 Complete customer assurance and production acceptance.
 - 9 Expand by channel, geography, business unit, and policy pack.
-

5. Reference architecture



Main components

Responsive Next.js application

Provides desktop, tablet, and mobile views; displays raw and protected transcripts side by side; exposes server-only proxy routes; and never places control-plane workload credentials in browser code.

Trusted WebSocket gateway

The browser-reachable voice entry point. It validates a short-lived host OIDC session, exact origin, expected tenant, protocol sequence, size, rate, duration, and connection limits. It rebuilds allowlisted control messages and injects a rotatable secret only on the private edge hop.

Self-hosted voice edge

Runs English faster-whisper and optional pyannote diarization. Audio remains within the customer environment. Every partial transcript pair is provisional and not safe for egress. The final audio chunk is always processed, including short utterances.

Python control plane

Owns workload authentication, tenant policy, detection, destination authorization, encrypted token mapping, evidence, retention, deletion, identity binding, and controlled reidentification.

PostgreSQL and token vault

Store tenant-scoped encrypted mappings and metadata. Each mapping uses a random data-encryption key and nonce. The key is wrapped by Azure Key Vault or OpenBao Transit. Plain identifiers are not written to the evidence chain.

Approved AI destinations

Can be local Ollama, a customer model platform, or an approved hosted model reached through a controlled route. Destinations receive protected text only after policy permits the route.

Evidence and immutable export

Each tenant has a signed hash chain. Verified exports should be transferred to customer-controlled retention-locked storage. The local database chain detects edits and gaps; an independently administered external anchor is required to detect a rollback of the entire database and ledger state together.

Trust boundaries

- **Endpoint boundary:** authorized raw display and ephemeral capture.
- **Gateway boundary:** browser identity and protocol enforcement.
- **Private model boundary:** speech and diarization.
- **Control boundary:** tenant policy, decision, and vault operations.
- **Key-custody boundary:** wrapping/signing outside application pods.
- **AI boundary:** protected content only.
- **Evidence boundary:** metadata-only export and external retention.

6. Security, identity, and data lifecycle

Identity model

AirShield separates authentication from diarization:

- The client host proves who is signed in or verified.
- Diarization labels voice continuity such as Speaker A or Speaker B.
- A signed host assertion may bind a verified subject to a track when channel provenance is trustworthy.
- AirShield stores a keyed digest of the host subject and emits an unrelated speaker token to AI.
- If evidence is insufficient, the person stays UNKNOWN.

An LLM is never used to prove identity. Optional voice biometrics would require a separately governed anti-spoofing, consent, bias, and legal program.

Cryptographic design

- AES-256-GCM per record with random data-encryption key and nonce.
- Additional authenticated data binds tenant, session, token, and entity type.
- Azure Key Vault or OpenBao Transit wraps data-encryption keys and signs evidence.
- HMAC-SHA-256 keyed indexes avoid unsalted low-entropy lookup hashes.
- Workload identity replaces long-lived cloud credentials.
- PostgreSQL production connections require certificate verification.

Data lifecycle

Data	Default location	Default handling
Raw audio	Private edge memory	No AirShield persistence by default
Raw transcript	Authorized local UI/edge memory	Not stored in control-plane evidence
Protected transcript	Local UI and approved destination	Destination retention is customer-controlled

Data	Default location	Default handling
Token mapping	Tenant-scoped PostgreSQL	Encrypted with wrapped per-record key until expiry/deletion
Identity binding	Tenant-scoped PostgreSQL	Keyed subject digest and assurance metadata
Evidence	Tenant hash chain	Metadata only; export to immutable customer storage
Workload JWT	Process memory	Verified claims only; raw token not persisted

Fail-closed principles

- Missing contextual detector, policy, database, key service, identity mapping, or signed final receipt blocks production egress.
- [review](#) is not treated as safe for egress.
- Browser-supplied tenant, trust, and gateway-secret fields are discarded.
- Destination values are policy identifiers, not caller-controlled URLs.
- Request, audio, connection, inference, and session limits are bounded.

7. Integration with new web and mobile applications

Recommended new-application pattern

- 1 The client application authenticates the user with its existing OIDC provider.
- 2 The host backend issues a short-lived Secure, HttpOnly session cookie for the AirShield gateway.
- 3 The browser opens WSS to the trusted gateway and streams microphone chunks.
- 4 The gateway sends audio to the private edge; transcript pairs return to the authorized UI.
- 5 Server-side application services call `/v1/protect` with workload identity for text, documents, prompts, or tickets.
- 6 Only protected output is submitted to the selected AI provider.
- 7 The application stores the receipt ID with its business record if evidence is required.

Frontend integration choices

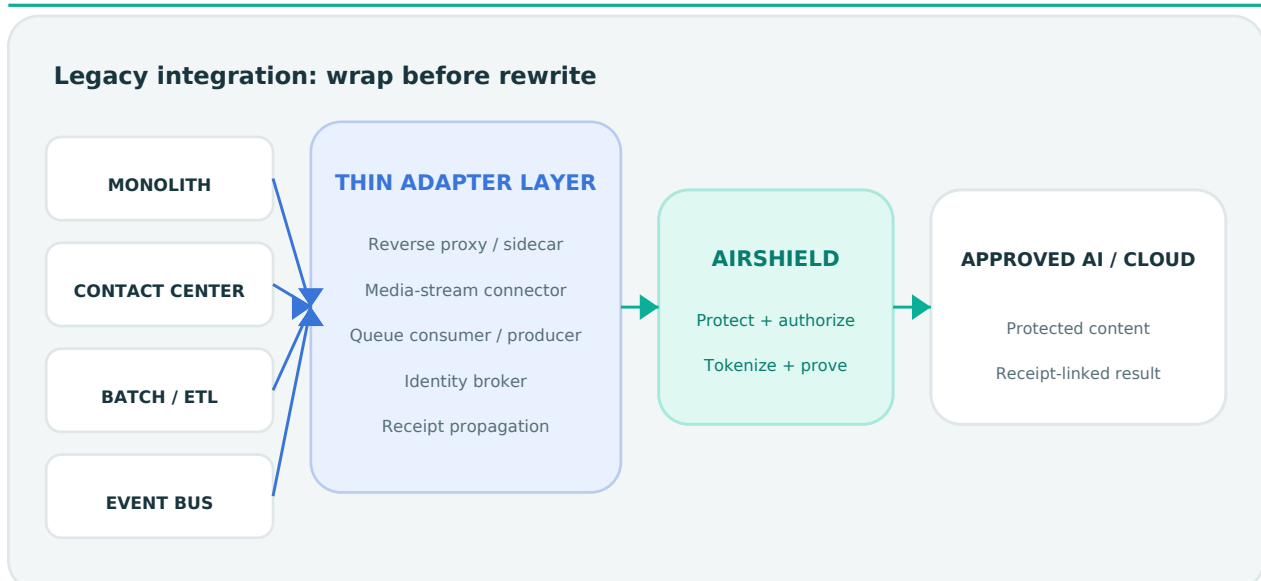
- Embed the AirShield LiveShield component into a React/Next.js application.
- Build a native UI against the AsyncAPI voice contract.
- Use a mobile WebView only after validating secure microphone, cookie, and WSS behavior.
- For native mobile, implement the same bounded WebSocket protocol and keep identity issuance server-controlled.

Backend integration choices

- Direct REST call from Java, .NET, Python, Go, or Node services using workload OIDC.
- API-gateway policy that calls AirShield before forwarding to an AI endpoint.
- Shared internal “AI access service” that combines AirShield protection with model routing.
- Sidecar for a single application when central platform integration is not yet available.

The repository includes example clients for Python, Node.js, Java, Go, and .NET plus OpenAPI and AsyncAPI contracts.

8. Integration with legacy applications



Principle: wrap before rewrite

AirShield should normally be introduced at an outbound boundary rather than embedded deep inside a legacy codebase. The goal is to intercept content before it reaches AI, cloud APIs, logs, or automation while preserving the existing application's business logic.

Integration patterns

Reverse proxy or API gateway

Route the legacy application's AI/API requests through a controlled adapter. The adapter extracts protectable text, calls AirShield, replaces the payload with protected text, and forwards only an allowed result. This is suitable when the application already calls HTTP services.

Sidecar or local agent

Deploy a small process beside the legacy application. The application calls localhost or a private service endpoint instead of the external model. The sidecar handles workload identity, retry policy, request mapping, and receipt propagation.

Message-bus adapter

For queue-driven systems, an adapter consumes a message, calls AirShield, publishes a protected message to a separate topic, and preserves the receipt ID and correlation metadata. Kafka/JMS-specific packaged connectors are a product roadmap item, not a completed connector in the current repository.

Contact-center or telephony media adapter

Fork an approved audio stream from the telephony/CCaaS platform into the private edge, then return protected transcript events to agent assist. SIPREC, vendor media-stream, and CTI connectors require customer/vendor-specific adapters and are not part of the current core source.

Batch and ETL protection

Place AirShield before AI enrichment of tickets, documents, call transcripts, or logs. Chunking, file parsing, reconciliation, and destination-specific semantics should live in a batch adapter while the control plane remains the authoritative policy decision point.

Database-trigger integration—use cautiously

Avoid database triggers that copy raw values into new systems. Prefer an application or change-data-capture adapter that protects content in a restricted processing zone and writes only protected output downstream.

Legacy identity bridge

- Translate service accounts, Kerberos identities, client certificates, or mainframe job identities into short-lived OIDC workload tokens through an approved identity broker.
- Create exact subject-to-tenant/scope mappings; do not use wildcard service subjects.
- Preserve the legacy business correlation ID separately from the AirShield token mapping.
- Keep reidentification outside the ordinary service account and require privileged workflow approval.

Low-risk migration sequence

- 1 Inventory current AI/cloud/log egress.
- 2 Start with synthetic or approved test data in a private environment.
- 3 Add an adapter in observe-and-compare mode without sending raw data to a new destination.
- 4 Validate recall, false positives, latency, failure handling, and business usability.
- 5 Enforce destination blocking for one workflow.
- 6 Expand to additional entities and channels.
- 7 Retire duplicate masking logic after evidence shows equivalent or better control.

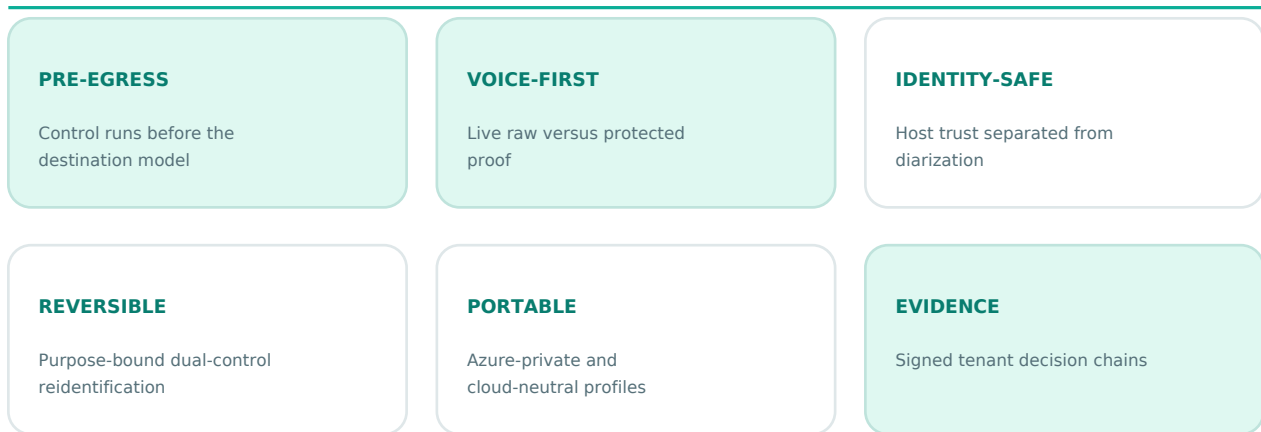
9. Technology stack

Layer	Technology	Why it is used
User experience	Next.js App Router, React, TypeScript, responsive CSS	Modern responsive application and server-only proxy boundaries
Voice transport	Browser MediaRecorder, WSS, FastAPI/WebSockets gateway	Low-latency streaming with explicit authenticated protocol
Speech recognition	faster-whisper English model	Self-hosted speech-to-text without mandatory per-minute API fees
Speaker continuity	Optional pyannote.audio	Local diarization; continuity only, not identity proof
Detection	Presidio Analyzer, spaCy, deterministic and custom rules	Contextual plus domain-specific entity recognition
Privacy control	Python FastAPI	Clear security boundary, typed APIs, policy and evidence workflows
Token protection	AES-256-GCM, HMAC-SHA-256, wrapped per-record keys	Confidentiality, integrity, contextual binding, safer lookup
Key custody	Azure Key Vault or OpenBao Transit	Cloud-private and portable key wrapping/signing
Persistence	PostgreSQL, SQLAlchemy, Alembic	Tenant-scoped transactional state and controlled migrations
Identity	OIDC/Entra or portable projected tokens; SPIFFE-compatible model	Short-lived verified workload identity
Deployment	Docker, Kubernetes, AKS, Bicep, Kustomize	Local pilot, Azure-private, and cloud-neutral operation
AI destination	Customer-approved models; optional Ollama	Provider-neutral protected routing and local demonstration
Contracts	OpenAPI and AsyncAPI	Language-independent REST and voice integration
Assurance	pytest, Ruff, mypy, npm audit, pip-audit, kubeconform	Repeatable quality and security gates

Deployment options

- **Azure private reference:** private AKS, private PostgreSQL Flexible Server, separate identities and vaults, private endpoints/DNS, customer ingress, diagnostics, and workload identity.
- **Cloud-neutral Kubernetes:** projected OIDC or SPIFFE-compatible identity, OpenBao Transit, NetworkPolicy, external PostgreSQL, customer ingress, and immutable evidence sink.
- **Development Compose:** UI, PostgreSQL, control plane, and voice edge for demonstration only. Visible development credentials and insecure localhost transport must never be promoted to production.

10. Why AirShield is differentiated



AirShield should not claim to be the first privacy or de-identification product. Its defensible position is the combination of capabilities and the quality of execution.

Differentiating combination

- 1 Pre-egress control:** privacy runs before the destination model, not after the provider has already received raw data.
- 2 Voice-first proof:** raw speech and protected outbound text are visible side by side in real time.
- 3 Identity discipline:** authentication comes from the trusted host; diarization only maintains track continuity.
- 4 Reversible utility with governance:** tokenization supports approved operational use while dual-control reidentification limits abuse.
- 5 Signed decision evidence:** metadata receipts connect policy, destination, result, entity counts, hashes, and tenant chain.
- 6 Provider independence:** the same layer can protect content for local models, Azure-hosted systems, other model providers, or internal tools.
- 7 Private and portable deployment:** Azure-native operation without making Azure the only deployment choice.
- 8 Fail-closed production posture:** unsigned, unavailable, below-policy, or review states are not presented as safe AI output.
- 9 Cross-channel reuse:** one control plane can protect voice, prompts, tickets, documents, and logs.
- 10 Legacy-friendly adoption:** gateways and sidecars can reduce the need to rewrite core applications.

Potential moat

The long-term moat is not a single regex or model. It is the accumulated combination of:

- representative, legally approved evaluation datasets and acoustic test suites;
- client-specific recognizers and policy packs;
- proven low-latency integration connectors;
- evidence and assurance accepted by enterprise review teams;
- deployment playbooks for regulated private environments;
- measured performance across accents, noise, channels, and sector jargon;
- operational trust earned through transparent failure behavior.

11. Business model and go-to-market

Buyer and stakeholder map

Role	What they care about	AirShield message
CEO/business sponsor	Speed, differentiation, client trust, margin	Unlock sensitive AI opportunities with a reusable privacy layer
CIO/CTO	Architecture, portability, integration effort	One model-neutral control plane for new and legacy applications
CISO	Data exposure, identity, keys, evidence, failure modes	Private deployment, workload identity, encrypted mappings, fail-closed egress
DPO/privacy/legal	Minimization, purpose, retention, rights, transfers	Reduce raw disclosure and provide policy/evidence inputs for governance
Head of AI/data	Model freedom, quality, latency, developer experience	Protect once, route to approved models through stable APIs
Operations/contact center	Agent experience and turnaround time	Live protection without manual redaction as the default process
Procurement/vendor risk	Supplier dependence and assurance	Customer-controlled deployment and explicit responsibility model

Recommended packaging

- 1 Privacy discovery and design package:** data-flow workshop, use-case selection, policy starter, DPIA/control inputs, and pilot plan.
- 2 Pilot platform license:** one use case, one environment, bounded capacity, implementation support, and agreed acceptance gates.
- 3 Enterprise platform license:** capacity/deployment tier, policy packs, multiple applications, evidence export, upgrades, and support.
- 4 Add-ons:** regulated connector packs, managed model evaluation, premium support, additional environments/regions, and assurance evidence services.

A capacity- or deployment-based commercial model reinforces the value of avoiding mandatory per-minute speech fees. Customer-specific cloud compute, storage, security operations, and implementation remain separate TCO components.

Land-and-expand motion

- Land with one blocked, high-value AI workflow.
- Prove pre-egress masking, usability, and evidence.
- Expand to more queues, business units, data types, and destinations.
- Standardize AirShield as the enterprise privacy gate for AI access.

Sales proof points

- A live side-by-side demonstration using customer-approved test patterns.
- A measured evaluation report rather than a generic accuracy claim.
- A clear private architecture and responsibility matrix.
- A legacy integration plan that avoids a core rewrite.
- A pilot scorecard with go/no-go criteria.

12. ROI and executive scorecard

Value model

Annual value can be modeled as:

- manual redaction/review hours avoided;
- managed speech/model usage cost avoided where self-hosting is economical;
- faster time-to-production for AI initiatives;
- reduced duplicate masking engineering across applications;
- expected reduction in privacy-event impact and investigation effort;
- revenue enabled by regulated-client confidence or differentiated product offers.

Annual TCO includes:

- platform license and implementation;
- compute for speech, detection, gateway, database, and model destination;
- security operations, monitoring, backup, and key management;
- model evaluation, policy maintenance, support, and assurance reviews.

A responsible business case should treat incident avoidance as a risk-adjusted estimate, not guaranteed savings.

Pilot KPIs

Privacy quality

- Entity recall by type and approved population slice.
- Escaped-identifier rate on representative end-to-end audio and text.
- False-positive rate and business-meaning preservation.
- Percentage of uncertain sessions blocked or reviewed correctly.

Product performance

- Streaming partial and final p50/p95 latency.
- Concurrent-session capacity per deployment profile.
- Availability and dependency-failure behavior.
- Agent/user task completion and correction rate.

Governance and operations

- Percentage of AI routes covered by an approved policy.
- Signed receipt completeness and immutable export success.
- Reidentification frequency, approval time, and exceptions.
- Retention/deletion job success and restore-test outcomes.

Commercial impact

- AI projects unblocked.
- Manual review hours avoided.
- Time from use-case approval to pilot.
- Expansion pipeline across channels/business units.

13. Pilot and production roadmap

Phase 0 — Executive alignment (1-2 weeks)

- Choose one use case, owner, geography, destination model, and success definition.
- Agree what data must never leave the boundary.
- Confirm customer roles, infrastructure owner, and assurance stakeholders.
- Identify representative approved test data and prohibited test data.

Phase 1 — Architecture and policy (2-3 weeks)

- Map flows, identities, destinations, logs, retention, and reidentification needs.
- Select Azure-private or portable Kubernetes profile.
- Configure sector policy and custom identifiers.
- Build the minimum legacy/new-application adapter.

Phase 2 — Controlled pilot (3-6 weeks)

- Deploy in a restricted non-production environment.
- Evaluate ASR, diarization where needed, detector recall, false positives, latency, and failure cases.
- Conduct tenant, authentication, key, logging, deletion, and evidence tests.
- Run business-user acceptance with synthetic or legally approved data.

Phase 3 — Production acceptance

- Complete legal/privacy review, threat-model review, penetration test, model risk acceptance, infrastructure validation, and applicable assessor work.
- Pin models and images; configure private certificates, keys, immutable evidence, monitoring, backup, and recovery.
- Define operational ownership, incident response, support, and change approval.

Phase 4 — Expansion

- Add channels, connectors, languages only after separate evaluation, policy packs, and additional destinations.
- Establish a model/policy release train and quarterly evidence review.

Suggested go/no-go gates

- Every critical entity and population slice meets the customer-approved recall target.
 - Final end-to-end leakage is below the approved threshold.
 - p95 latency is acceptable for the workflow.
 - Unsafe dependency states demonstrably block egress.
 - Tenant isolation and reidentification abuse tests pass.
 - Customer legal, privacy, security, and operational owners sign acceptance.
-

14. What is implemented and what remains

Implemented in the current source

- Responsive Next.js desktop/tablet/mobile experience.
- Live microphone recorder and private WebSocket path.
- Side-by-side raw and protected transcript display.
- Self-hosted English edge adapter and short-final-chunk processing.
- Authenticated gateway and private-edge protocol reconstruction.
- Python control plane with tenant policy and destination decisions.
- Encrypted token vault, retention/deletion, identity binding, controlled reidentification.
- Signed tenant evidence chains and verified export workflow.
- Azure and OpenBao/Kubernetes deployment references.
- OpenAPI/AsyncAPI and example clients for major languages.
- Automated tests, linting, typing, contract checks, and dependency audits.

Latest repository checks include 32 control-plane tests, 9 edge tests, 6 gateway tests, 2 contract tests, a successful Next.js production build, and no high-level npm audit findings. The synthetic detector fixture is deliberately marked as insufficient for production promotion.

Release-blocking work

- Representative, legally sourced ASR/detection/diarization evaluation across actual client conditions.
- Live model/codec/load/soak tests in the target infrastructure.
- Customer host issuance of pinned Secure, HttpOnly gateway sessions and receipt-key verification.
- Production ingress, WAF/DDoS, FQDN-aware egress, monitoring, immutable evidence sink, and disaster recovery.
- Customer-specific connectors, policies, notices, retention, and rights workflows.
- Independent security, privacy, legal, penetration, model, and applicable sector/PCI assessment.

No codebase or AI-generated document should be presented as certification.

15. Risks, objections, and responses

Executive objection	Response	Proof required
"What if it misses an identifier?"	Use representative evaluation, critical-entity thresholds, full-session recheck, and fail-closed routing	Slice-level recall and end-to-end leakage report
"What if masking ruins the AI result?"	Tokenization preserves relationships; policies can generalize or tokenize by entity; evaluate task utility alongside privacy	Business-task quality and false-positive study
"Will it slow live calls?"	Keep speech and detection close to the workload, stream provisional pairs, size capacity, and measure p95	Production-like latency/load test
"Why not use the model provider's redaction?"	Provider-side redaction happens after content reaches that provider and creates model lock-in	Data-flow comparison and contract review

Executive objection	Response	Proof required
"Can our team build this?"	Basic masking is easy; secure identity, private voice, key custody, evidence, reidentification, policy lifecycle, and evaluation create the product burden	Build-vs-buy TCO and delivery-risk analysis
"Does this make us compliant?"	It supplies technical controls and evidence inputs; organizational and legal obligations remain	Customer DPIA/risk assessment and assessor review
"Can authorized staff recover a value?"	Yes, through purpose-bound, separate approval, expiring, one-time retrieval	Reidentification abuse and audit test
"Can it work with our old platform?"	Place a gateway, sidecar, media adapter, or queue adapter at the outbound boundary	A thin proof-of-integration against the real interface
"What if KMS or policy is down?"	Production egress stops rather than silently forwarding raw text	Dependency-outage demonstration

16. Questions a CEO is likely to ask

Who pays for it?

The economic buyer may be the CIO/CTO, CISO, Chief Data/AI Officer, or business leader sponsoring a regulated AI workflow. Privacy/legal are essential approvers; operations and AI platform teams are key champions.

Is this a feature or a company/platform?

It becomes a platform when one deployment protects several channels, applications, and model destinations with common policy, evidence, and connectors. A single regex endpoint is a feature; a governed enterprise privacy control plane is a platform.

What is the first beachhead?

Choose an active voice or text AI project delayed by privacy review, with measurable volume and a motivated sponsor. Contact-center summarization in healthcare, finance, or insurance is a strong demonstration because the risk and value are both visible.

How do we avoid a long enterprise sales cycle?

Sell a bounded design-and-pilot package with a clear use case, private deployment option, fixed acceptance scorecard, and an integration path that does not require core-system replacement. Build reusable assurance material so each opportunity does not restart from zero.

What should we not claim?

Do not claim universal de-identification, perfect detection, guaranteed compliance, certification, legal anonymity, or that voice diarization identifies a real person. Do not claim market-first status without independent competitive research.

What drives gross margin?

Software licensing and reusable policy/connectors can scale better than project-only consulting. Self-hosted capacity avoids pass-through per-minute speech fees, but support, evaluation, private deployment, and client-specific integration must be standardized to protect margin.

What creates defensibility?

Evaluation assets, deployment trust, connector coverage, policy/evidence workflow, operational reliability, and accumulated client-specific expertise—not the public model components alone.

What is the biggest technical risk?

False negatives caused by ASR errors, accents, noise, novel identifiers, Unicode/evasion, and context. The answer is measured end-to-end quality gates and safe failure behavior, not marketing accuracy.

What is the biggest commercial risk?

Becoming a custom-services project for every client. The mitigation is a narrow initial use case, standard connector interfaces, versioned policy packs, automated assurance, and repeatable deployment tiers.

What should the next investment buy?

- 1 Two or three design partners with real use cases.
- 2 Representative approved evaluation data and a release-quality scorecard.
- 3 One high-value telephony/contact-center connector and one model-gateway connector.
- 4 External security/privacy review and production Azure validation.
- 5 Productized policy administration, monitoring, evidence export, and upgrade operations.

17. Product roadmap opportunities

Near-term

- Policy Studio with versioning, approval, simulation, and rollback.
- Evaluation workbench for false negatives, false positives, utility, and latency.
- Risk score before and after protection.
- Packaged model-gateway, contact-center, Kafka/JMS, and ticketing connectors.
- Customer dashboard for signed evidence export, deletion, and policy coverage.
- Deployment sizing calculator and capacity benchmark profiles.

Medium-term

- Domain-adapted recognizers and acoustic evaluation packs.
- Protected multimodal document intake.
- Privacy-safe agent/tool gateway controls in addition to identifier protection.
- Customer-managed policy marketplace and verified connector SDK.
- Multi-region control-plane resilience and offline/edge-site profiles.

Guardrails for expansion

Every new language, biometric feature, model, entity type, connector, and region needs separate accuracy, security, privacy, legal, and operational acceptance. Expansion should not weaken the core promise that raw identity stays inside the approved boundary.

18. Recommended executive decisions

- 1 **Approve a focused pilot strategy**, not a broad “protect everything” launch.
- 2 **Select one regulated design partner and one internal reference workflow.**
- 3 **Fund evaluation and connectors before additional visual features.**
- 4 **Adopt a platform license plus implementation/support model**, avoiding commodity per-minute positioning.
- 5 **Require honest assurance language** in every sales artifact.
- 6 **Define production acceptance gates** owned jointly by engineering, security, privacy, and the client business owner.
- 7 **Measure expansion economics:** integration effort, infrastructure cost, policy reuse, support load, and annual contract potential.

Final perspective

AirShield is compelling because it does not ask enterprises to stop using AI. It gives them a way to introduce a privacy enforcement point before sensitive content reaches models and tools. The product can become strategically valuable if the company focuses on measurable quality, integration simplicity, private deployment trust, and reusable enterprise assurance.

Best closing line: “Use AI on sensitive work—without making raw identity the price of admission.”

Appendix A. Integration decision guide

Environment	Preferred pattern	Identity	Primary concern
New React/Next web app	WSS gateway + server-side REST proxy	User OIDC + workload OIDC	Never expose service credentials in browser
Native mobile app	Native recorder + authenticated WSS	Host-issued short-lived session	Certificate, background capture, device security
Java/.NET monolith	Sidecar or internal API gateway	Workload OIDC via broker	Minimal code change and retry semantics
Contact-center platform	Vendor media-stream adapter	Agent/caller host context	Audio consent, latency, multi-party tracks
Batch document pipeline	Restricted batch adapter	Job workload identity	Chunking, reconciliation, destination retention
Event-driven platform	Consumer/protector/producer adapter	Service workload identity	Ordering, idempotency, dead-letter privacy
Internal model gateway	Central pre-prompt policy hook	Platform workload identity	Prevent bypass and preserve receipt linkage

Appendix B. Responsibility summary

AirShield/product team

- Maintain code, contracts, policy framework, security fixes, deployment reference, and release evidence.
- Publish supported versions and model/policy compatibility.
- Provide clear failure modes and operational guidance.

Customer platform/security team

- Operate identity, private network, certificates, key stores, database, monitoring, backup, immutable evidence, and incident response.
- Restrict raw-pane access and downstream destinations.
- Approve workload/tenant mappings and reidentification roles.

Customer privacy/legal/risk team

- Define purposes, lawful basis, notices/consent where required, retention, data-subject handling, transfer position, and sector obligations.
- Approve evaluation data and residual risk.

Business owner

- Define task utility, acceptable latency, human review, escalation, and pilot success.
- Confirm that protected output remains useful and that reidentification is necessary and proportionate.

Appendix C. Important assurance statement

AirShield can support GDPR, Nordic national requirements, HIPAA where applicable, PCI DSS 4.0.1, NIS2, DORA, EHDS, and EU AI Act programs through technical controls and evidence. Applicability, roles, legal basis, validation method, and compliance conclusions depend on the customer, country, sector, deployment, and use case. Independent legal, privacy, security, model, penetration, and applicable assessor review remains required.